

GestPro

ERP SaaS multi-tenant para empresas moçambicanas — visão de sistema, arquitectura, diagramas e balanço do que está feito, do que falta e do que deve ser melhorado.



Versão	1.0	Base de análise	Código-fonte do monorepo <code>gespro</code> — <code>apps/erp</code> , <code>apps/site</code> , <code>infra/</code> , <code>.kiro/specs</code> , <code>docs/</code>
Data	20 de Agosto de 2026	Último commit analisado	<code>7794428</code> — <code>merge(fix/contactos-login)</code> , 24 de Julho de 2026
Âmbito	Sistema completo	Audiência	Direcção e liderança técnica; secções 2 a 8 destinam-se a engenharia

Como ler este documento

As secções 0, 1 e 9 a 12 respondem às perguntas de gestão: o que o sistema faz, em que estado está e o que falta decidir. As secções 2 a 8 descrevem a arquitectura com o detalhe necessário a quem vai manter ou auditar o código.

0	Sumário executivo O sistema em números, estado de maturidade e a recomendação	6	Máquinas de estado 50 mapas de transição, 49 ciclos de vida distintos
1	Visão de produto e âmbito funcional Os 22 módulos, conformidade moçambicana e modelo de negócio	7	Casos de uso e autorização Perfis RBAC e o catálogo de 298 permissões
2	Arquitectura Contexto, alto nível, baixo nível e invariantes estruturais	8	Qualidade, segurança e operação Testes, gates de CI, hardening, observabilidade e deploy
3	Fluxo de dados e isolamento multi-tenant As três vias de entrada e as duas correntes de contexto	9	O que já foi feito Balanço das sete waves de construção
4	Modelo de domínio e contratos Diagrama de classes, interfaces publicadas e hierarquia de erros	10	O que ainda não foi feito Lacunas conhecidas, com impacto e bloqueio
5	Sequência de eventos: venda no POS O fluxo transaccional mais crítico, passo a passo	11	O que deve ser melhorado Dívida técnica priorizada por severidade e esforço
		12	Riscos e recomendação Sequência sugerida até ao primeiro cliente em produção

Nota sobre a fonte dos dados

Todos os números deste documento foram extraídos por contagem directa sobre o código-fonte na data indicada, e não de documentação anterior. O ficheiro docs/DOCUMENTACA0.md existente no repositório descreve a arquitectura anterior à migração (dados mock, PostgREST, Next.js 15) e está desactualizado — ver secção 11.

0. Sumário executivo

O GestPro é um ERP completo, multi-tenant, desenhado de raiz para o contexto fiscal e operacional moçambicano. Está funcionalmente construído e verificado em ambiente de desenvolvimento; o que separa o produto do primeiro cliente pago não é código de negócio, mas validação de produção.

174

modelos de dados Prisma, distribuídos por nove *schemas* de domínio

304

páginas da aplicação em 22 módulos de negócio

231

Server Actions, cada uma com permissão declarada

51

serviços de domínio por trás de 36 interfaces

1 199

testes automatizados, verdes no último gate

~158 k

linhas de TypeScript e TSX no ERP

O que o sistema faz

Cobre a operação inteira de uma PME: compras e fornecedores, inventário e activos, comercial com ponto de venda, finanças com contabilidade de partida dobrada sobre o plano de contas PGC-NIRF, recursos humanos com processamento salarial moçambicano, projectos, produção, transporte e helpdesk.

Cada empresa é um *tenant* isolado sobre a mesma base de dados. O site público de marketing, o registo *self-service* e a subscrição via Stripe fecham o ciclo comercial sem intervenção manual.

O que o distingue

Não é um ERP genérico traduzido. Metical como moeda de primeira classe em `Decimal`, validação de NUIT e BI, plano de contas do Decreto 70/2009 com 504 contas carregadas, tabelas de INSS e escalões de IRPS versionados por vigência, e numeração fiscal sequencial garantidamente sem lacunas.

Em que estado está

O programa de construção decorreu em sete waves, todas concluídas e fechadas com revisão de código formal. A última terminou a 24 de Julho de 2026.

Backend e modelo de domínio	COMPLETO
Interface e experiência de utilizador	COMPLETO
Integração transaccional entre domínios	COMPLETO
Segurança aplicacional e RBAC	COMPLETO
Observabilidade e CI/CD	COMPLETO
Site público e onboarding SaaS	POR VALIDAR
Infraestrutura provisionada em AWS	POR EXECUTAR
Operação em produção com clientes reais	POR INICIAR

O código de infraestrutura existe e foi revisto, mas `terraform apply` nunca correu — não houve credenciais AWS no ambiente de desenvolvimento.

0. Riscos dominantes e onde investir agora

Nenhum destes riscos é de concepção. São todos de execução — e risco de execução converte-se em tarefas estimáveis assim que o sistema arranca uma primeira vez num ambiente real.

Os três riscos que concentram a exposição

1 • O caminho para produção nunca foi percorrido

Terraform por aplicar, Stripe nunca contactado em modo de teste real, Lighthouse e deploy do site por correr. Tudo o que falha em produção mas não em desenvolvimento continua desconhecido.

2 • Limitador de tráfego apenas em memória

A porta de *rate limiting* está desenhada mas só tem adaptador em memória, por processo. Abrir o registo público sem um backend partilhado deixa o formulário exposto a abuso distribuído.

3 • Auditoria não cobre documentos financeiros

A extensão de auditoria regista apenas `User`, `Role` e `Permission`. Facturas, lançamentos contabilísticos e movimentos de caixa ficaram por adicionar — está escrito como intenção no código, nunca implementado.

4–6

semanas de trabalho conhecido separam o sistema do primeiro cliente pago

0

funcionalidades de negócio em falta na lista de bloqueadores

3

decisões externas por fechar: fiscalidade da subscrição, fornecedor de captcha e ambiente AWS

Recomendação

Não abrir mais frentes funcionais. As próximas quatro a seis semanas devem ser dedicadas exclusivamente a três coisas, por esta ordem:

(a)

provisionar a infraestrutura e executar um *deploy* real com *smoke* ponta-a-ponta, incluindo Stripe em modo de teste;

(b)

fechar os dois bloqueadores de segurança — *rate limiting* distribuído e auditoria dos documentos financeiros;

(c)

validar a fiscalidade moçambicana da própria subscrição, que continua em aberto no ADR-0009. Só depois disto faz sentido discutir novas funcionalidades.

O que este documento não conclui

Não há qualquer medição de comportamento sob carga — nem cenários, nem ferramenta, nem histórico. Quantos *tenants* cabem numa instância, qual a latência do balancete com um ano de lançamentos, e quanto custa servir um cliente médio continuam por responder. É informação necessária para precificar.

O que dá confiança

Treze rejeições em revisão formal ao longo do programa, em onze entregas distintas, quase todas por isolamento de *tenant* ou por atomicidade transaccional — exactamente as duas classes de defeito que um cliente descobriria em produção. Foram apanhadas antes, e as correcções ficaram cobertas por teste.

Uma nota sobre manutenção

O sistema foi construído em duas semanas por agentes coordenados, com documentação de processo acima da média — mas nenhuma pessoa percorreu todo o código. Quem assumir a manutenção deve contar com tempo de familiarização antes de assumir compromissos de prazo.

1. Visão de produto e âmbito funcional

O GestPro entrega, num único produto, os sete domínios operacionais que uma PME moçambicana precisa de gerir — sem integrações entre sistemas de fornecedores diferentes e sem adaptações locais improvisadas em cima de um ERP estrangeiro.

1.1 Mapa de módulos

Cada módulo é uma área de navegação da aplicação com listagens, detalhes, formulários dedicados e painéis de indicadores. A coluna de páginas mede a dimensão real de cada área.

MÓDULO	DOMÍNIO	PÁGINAS	MÓDULO	DOMÍNIO	PÁGINAS	MÓDULO	DOMÍNIO	PÁGINAS
Projectos	Pessoas & Projectos	33	Tickets	Operações	14	Produtos	Inventário & Activos	4
Recursos humanos	Pessoas & Projectos	32	Fornecedores	Compras	13	Caixa	Finanças	3
Inventário	Inventário & Activos	31	Produção	Pessoas & Projectos	13	Notificações	Plataforma	2
Transporte	Operações	26	Serviços	Compras	13	Ponto de venda (POS)	Comercial	1
Vendas	Comercial	24	Clientes	Comercial	10	Analytics	Transversal	1
Contabilidade	Finanças	21	Facturação	Finanças	10	Definições	Plataforma	1
Compras	Compras	14	Gestão do tenant	Plataforma	10	Autenticação	Fundação	3
Procurement	Compras	14	Stock	Inventário & Activos	5	Outras rotas	raiz, dashboard legado, dev/patterns	6
						Total	22 módulos + auth	304

Como ler esta contagem

Cada linha é um ficheiro `page.tsx` — uma rota real da aplicação, com listagem, detalhe, formulário ou painel próprio. Não conta componentes nem fragmentos. A linha «outras rotas» agrupa a raiz da aplicação, quatro rotas legadas fora do grupo de *dashboard* e a página interna de demonstração de padrões. A dimensão dos módulos de Projectos, RH e Inventário reflecte a profundidade funcional exigida a um ERP completo, e não duplicação: os gates de CI garantem que nenhuma página lê dados simulados e que listagens e detalhes são renderizados no servidor.

1.2 Conformidade moçambicana

A localização não é uma camada de tradução — está no modelo de dados e nas regras de negócio.

REQUISITO	COMO ESTÁ RESOLVIDO
Moeda	Metical (MZN) em <code>Prisma.Decimal</code> em toda a persistência; nunca vírgula flutuante. A serialização para o cliente converte para <i>string</i> sem perda.
Identificação fiscal	Validadores de NUIT e BI partilhados por um único módulo, usados em clientes, fornecedores e colaboradores.
Plano de contas	PGC-NIRF do Decreto 70/2009 — 504 contas carregadas no <i>seed</i> , com árvore hierárquica, diários e centros de custo.
Contabilidade	Partida dobrada real: <code>Lancamento</code> com <code>PartidaLancamento</code> equilibradas, balancete e razão de conta gerados a partir do livro.
Segurança social	Tabelas de INSS versionadas por data de vigência, aplicadas pelo motor de processamento salarial.
Imposto sobre rendimento	Escalões de IRPS versionados; o motor de <i>payroll</i> tem cobertura de teste total.
Numeração fiscal	<code>proximoNumeroSerie</code> emite números por série com <code>UPDATE ... RETURNING FOR UPDATE</code> — atómico e sem lacunas, mesmo sob concorrência.
Idioma	Toda a interface e todas as mensagens em Português de Portugal.

1.3 Modelo de negócio e onboarding

O produto é vendido como subscrição. O percurso comercial está implementado ponta-a-ponta e não exige intervenção manual da equipa.

1. O visitante chega ao site de marketing (`apps/site`), que consome a API pública do ERP para obter planos e preços — sem preços codificados no site.
2. Regista-se; o pedido viaja com `Idempotency-Key` , protegido por campo-armadilha e limitador de tráfego dos dois lados.
3. Verifica o e-mail por *token*; o *tenant* é provisionado com plano de contas, papéis e permissões.
4. Um *token* de *handoff* transfere a sessão do site para o ERP sem nova autenticação.
5. A subscrição vive no Stripe. Os *webhooks* transitam o estado com *compare-and-set*: dois eventos concorrentes não se sobrepõem, e um evento cujo *tenant* não resolve devolve 503 com `Retry-After` em vez de ser silenciosamente descartado.

Duas decisões ainda por fechar

A moeda de facturação da própria subscrição está definida em USD no ADR-0009, mas a fiscalidade moçambicana dessa facturação continua por validar — é bloqueante antes de cobrar o primeiro cliente. E o fornecedor de *captcha* nunca foi escolhido: o campo `captchaToken` viaja vazio.

2. Arquitectura

O GestPro é um **monólito modular**: um único artefacto de *deploy*, uma única base de dados, e fronteiras de domínio explícitas que só comunicam por funções de contrato publicadas. A escolha é deliberada e está registada em ADR.

2.1 Decisões estruturantes

DECISÃO	RACIONAL E CONSEQUÊNCIA
Monólito modular em vez de microserviços	Uma venda tem de decrementar stock, registar caixa e emitir número fiscal <i>na mesma transacção</i> . Distribuir isto exigiria sagas e compensações para uma equipa pequena e um volume de PME. O custo é ter de defender as fronteiras por disciplina — o que os gates de CI fazem.
Next.js e Prisma ADR-0001	Um só ecossistema TypeScript do modelo de dados à interface. Server Components eliminam a camada de API interna: a página chama o serviço directamente.
Monorepo pnpm + Turborepo ADR-0006	ERP e site de marketing partilham <i>tokens</i> de marca e configuração, com builds independentes e cache incremental.
Contratos em vez de imports internos ADR-0003	Cada domínio publica funções; os consumidores importam o tipo canónico. Tipos-espelho locais foram proibidos, o que transformou o <code>tsc</code> no fiscal do contrato.
Chaves estrangeiras escalares entre domínios	<code>clienteId String</code> com índice, nunca <code>@relation</code> entre <i>schemas</i> de domínios diferentes. Mantém cada <i>schema</i> auto-contido e desacopla a fundação dos domínios.
Sem modais	Criar, editar e detalhar são rotas dedicadas. Única excepção: caixa de confirmação destrutiva. Um gate de CI falha o <i>merge</i> se aparecer um <code>Dialog</code> .

2.2 As quatro invariantes que sustentam tudo

O `tenantId` nunca vem do cliente

Vem sempre do contexto de sessão, propagado por `AsyncLocalStorage`. Uma escrita a um modelo multi-tenant sem contexto activo lança erro em vez de gravar sem isolamento — falha fechada, nunca silenciosa. Um acesso cross-tenant devolve 404, nunca 403, para não confirmar a existência do recurso.

Dinheiro é sempre `Decimal`

Nenhum valor monetário toca em vírgula flutuante. Ao atravessar a fronteira servidor→cliente é serializado para *string*, o que impede arredondamentos acidentais na camada de apresentação.

Documentos transaccionais são *append-only*

Facturas emitidas e lançamentos contabilísticos corrigem-se por estorno ou nota de crédito. Nunca por `UPDATE` de valores. O PDF fiscal *reflecte* o documento emitido — não recalcula nada no momento da impressão.

O estado muda por máquina de estados

50 mapas `TRANSICOES_X` declarados — 49 ciclos de vida distintos — sempre acompanhados de uma função `transitar()`. Nenhum serviço escreve um campo de estado directamente; uma transição inválida lança erro de regra de negócio com código estável.

2.3 Diagrama de contexto

Quem usa o sistema e de que sistemas externos depende. O GestPro é uma fronteira única: não há serviços internos a chamarem-se uns aos outros pela rede.

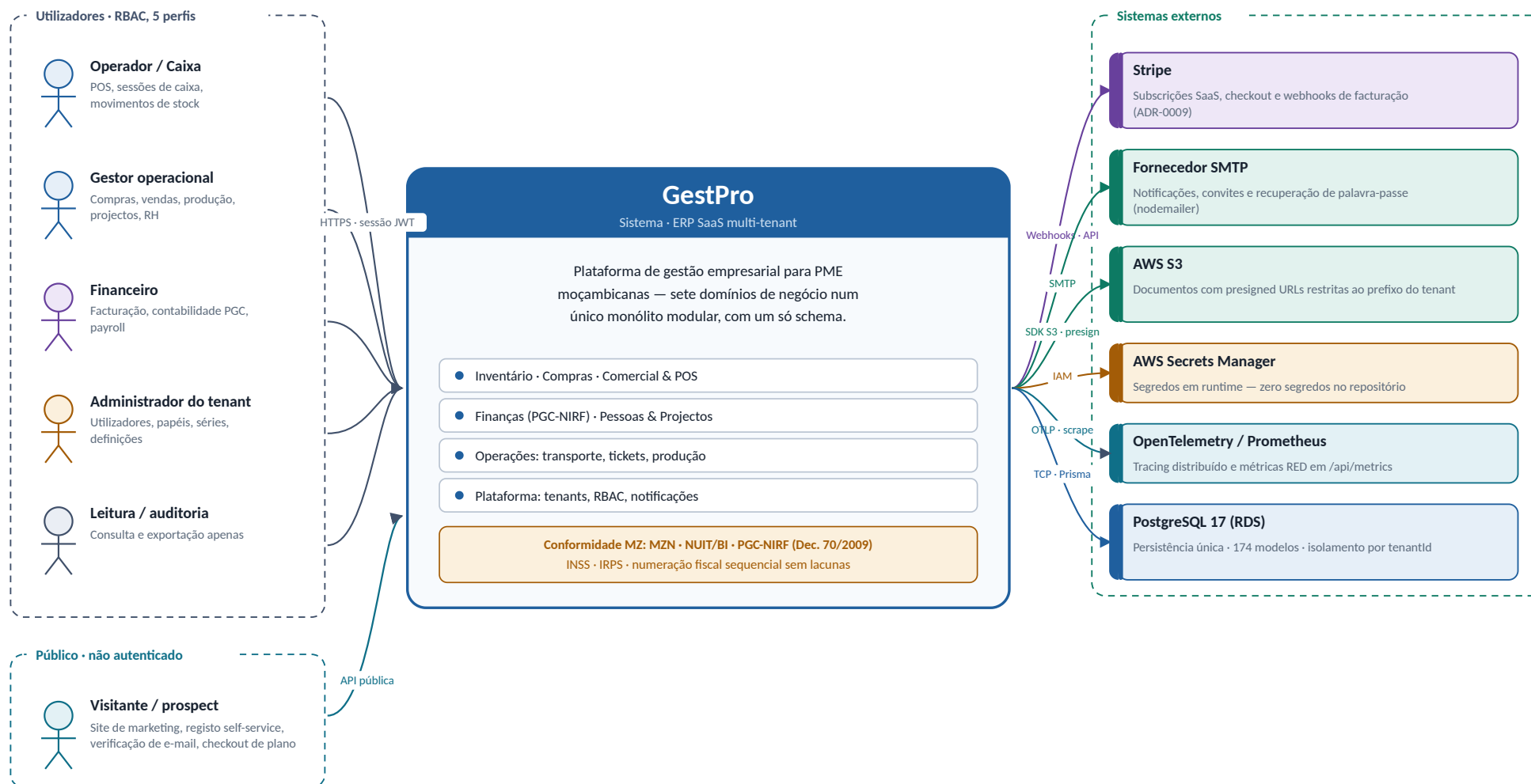


Figura 1 — Diagrama de contexto. Cinco perfis autenticados e um perfil público. Seis dependências externas, das quais apenas a base de dados é indispensável ao arranque: o armazenamento tem adaptador local para desenvolvimento e CI, e o envio de e-mail tem adaptador nulo.

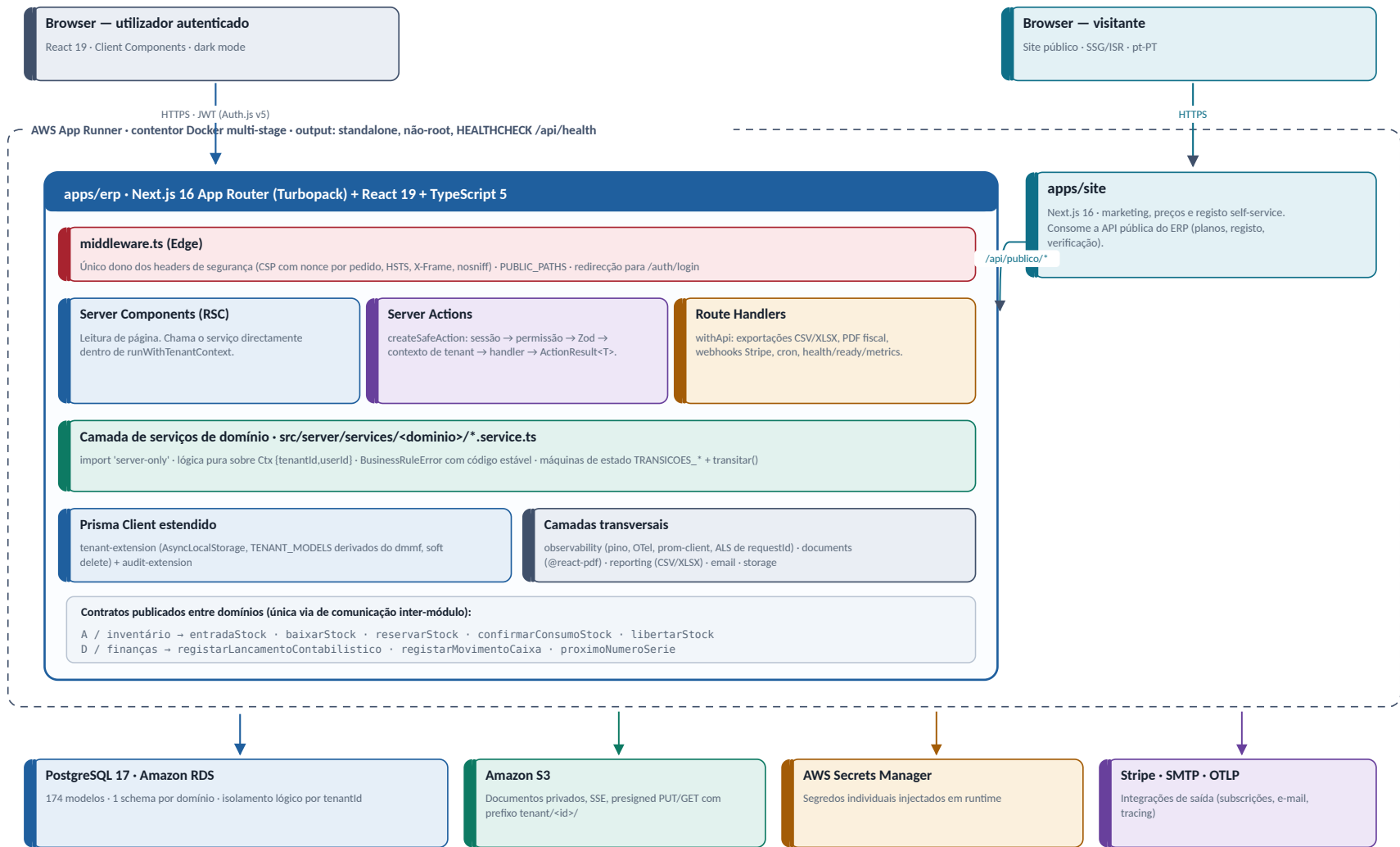


Figura 2 — Contentores e camadas internas do ERP. Note-se que existem três — e apenas três — portas de entrada no domínio: Server Components para leitura, Server Actions para mutação a partir da interface, e Route Handlers para exportações, *webhooks* e tarefas agendadas. Todas convergem na mesma camada de serviços.

2.5

Arquitectura de baixo nível

Os sete domínios — os *workstreams* A a G do programa de construção — o que cada um possui, e as duas únicas direcções em que as dependências podem correr.

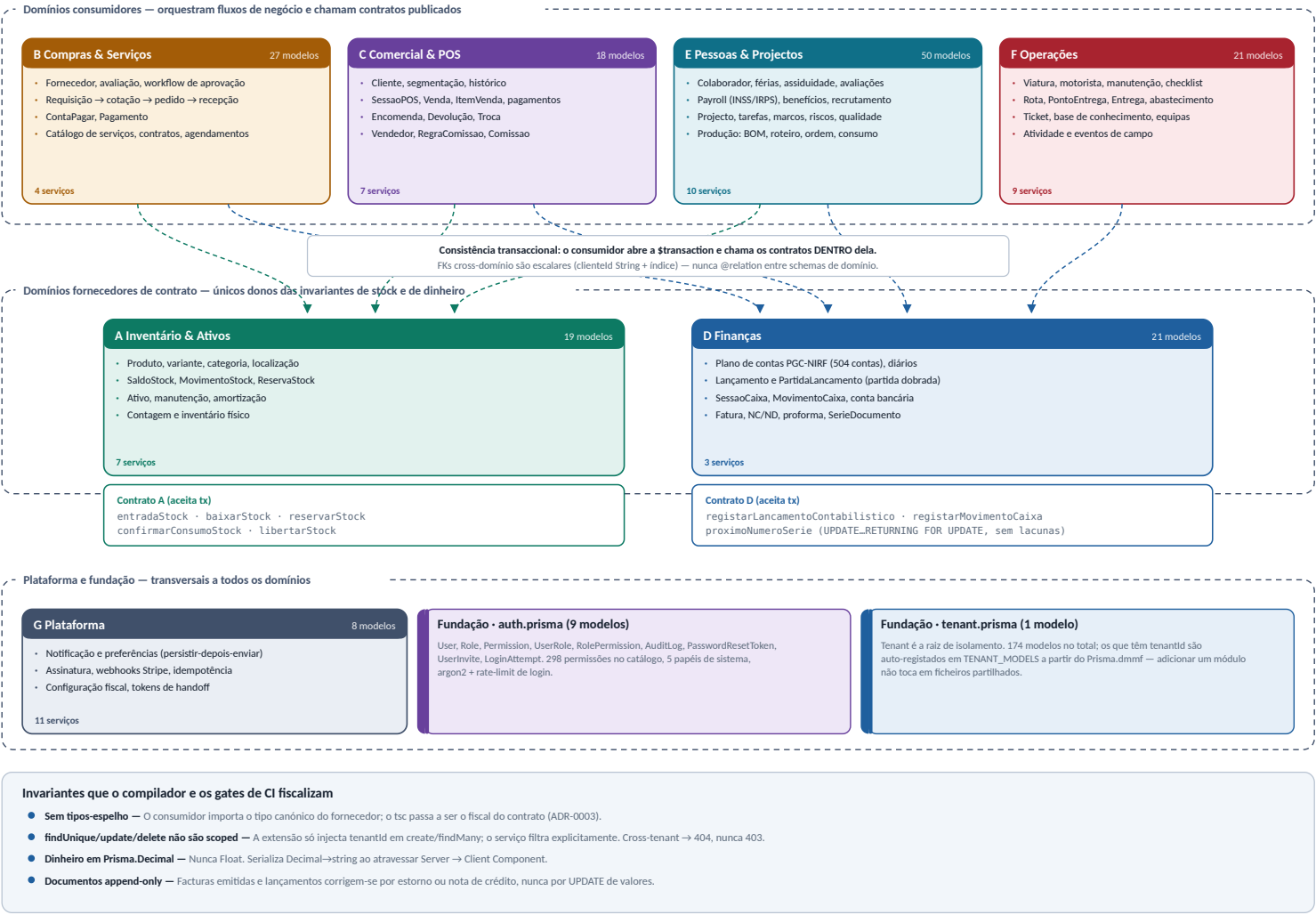


Figura 3 — Módulos de domínio e dependências de contrato. Inventário e Finanças são os donos exclusivos das invariáveis de stock e de dinheiro; ninguém escreve saldos ou lançamentos por fora. Os consumidores abrem a transacção e chamam os contratos *dentro* dela, o que garante que um fluxo de negócio confirma ou reverte em bloco.

3. Fluxo de dados e isolamento multi-tenant

Existem três percursos possíveis para um pedido, e os três terminam no mesmo sítio: um serviço de domínio a correr dentro de um contexto de *tenant* estabelecido pelo servidor. Nenhum deles aceita o identificador do *tenant* vindo do cliente.

3.1 Como funciona o isolamento

Uma extensão do cliente Prisma injecta o `tenantId` nas operações que o suportam. A lista de modelos abrangidos **não é mantida à mão**: é derivada do `Prisma.dmmf` em tempo de arranque — qualquer modelo com campo `tenantId` entra automaticamente. Acrescentar um domínio novo não toca em nenhum ficheiro partilhado.

O ponto que exige disciplina

A extensão só é capaz de injectar o filtro em `create`, `findMany` e afins. As operações `findUnique`, `update`, `delete` e `upsert` **não são filtradas** pela extensão — o serviço tem de incluir o `tenantId` explicitamente. Foi exactamente aqui que a revisão de código apanhou fugas cross-tenant reais em três waves diferentes.

Dentro de uma transacção que use o cliente cru (`prismaBase.$transaction`), a extensão não está activa de todo — o `tenantId` tem de constar de todas as escritas. Os testes de segurança que ficaram no repositório cobrem estes casos.

Eliminação lógica

Modelos com campo `deletedAt` são igualmente auto-detectados e filtrados. Não há apagamento físico de registos de domínio.

3.2 Integração transaccional entre domínios

São cinco os fluxos em que dois ou mais domínios têm de concordar num único acto. Todos seguem o mesmo padrão: o consumidor abre a transacção e passa o `tx` aos contratos.

FLUXO	EFEITOS COORDENADOS
Venda / POS	número de série → venda e itens → baixa de stock por item → movimento de caixa → histórico de estado
Encomenda	reserva de stock na criação; confirmação de consumo na facturação; libertação no cancelamento
Recepção de compra	entrada de stock → conta a pagar → lançamento contabilístico
Facturação	emissão do documento → lançamento de partida dobrada no plano de contas
Produção	consumo de componentes segundo a estrutura de produto → entrada do produto acabado
Processamento salarial	folha e linhas → movimento de caixa → lançamento contabilístico

Paginação

A paginação é **por cursor**, não por `skip` com deslocamento grande. Pede-se sempre um registo a mais do que o pedido para saber se existe página seguinte. É a escolha correcta para tabelas que crescem — e evita a degradação típica de listagens profundas.

Notificações

Padrão *persistir-depois-enviar*: a notificação é gravada em estado pendente **dentro** da transacção de negócio; o envio de e-mail acontece como efeito colateral **fora** dela. Uma falha do fornecedor de e-mail nunca desfaz a operação de negócio.

Figura 4 Vias de entrada e contexto Os três percursos possíveis de um pedido e as duas correntes de contexto que os acompanham.

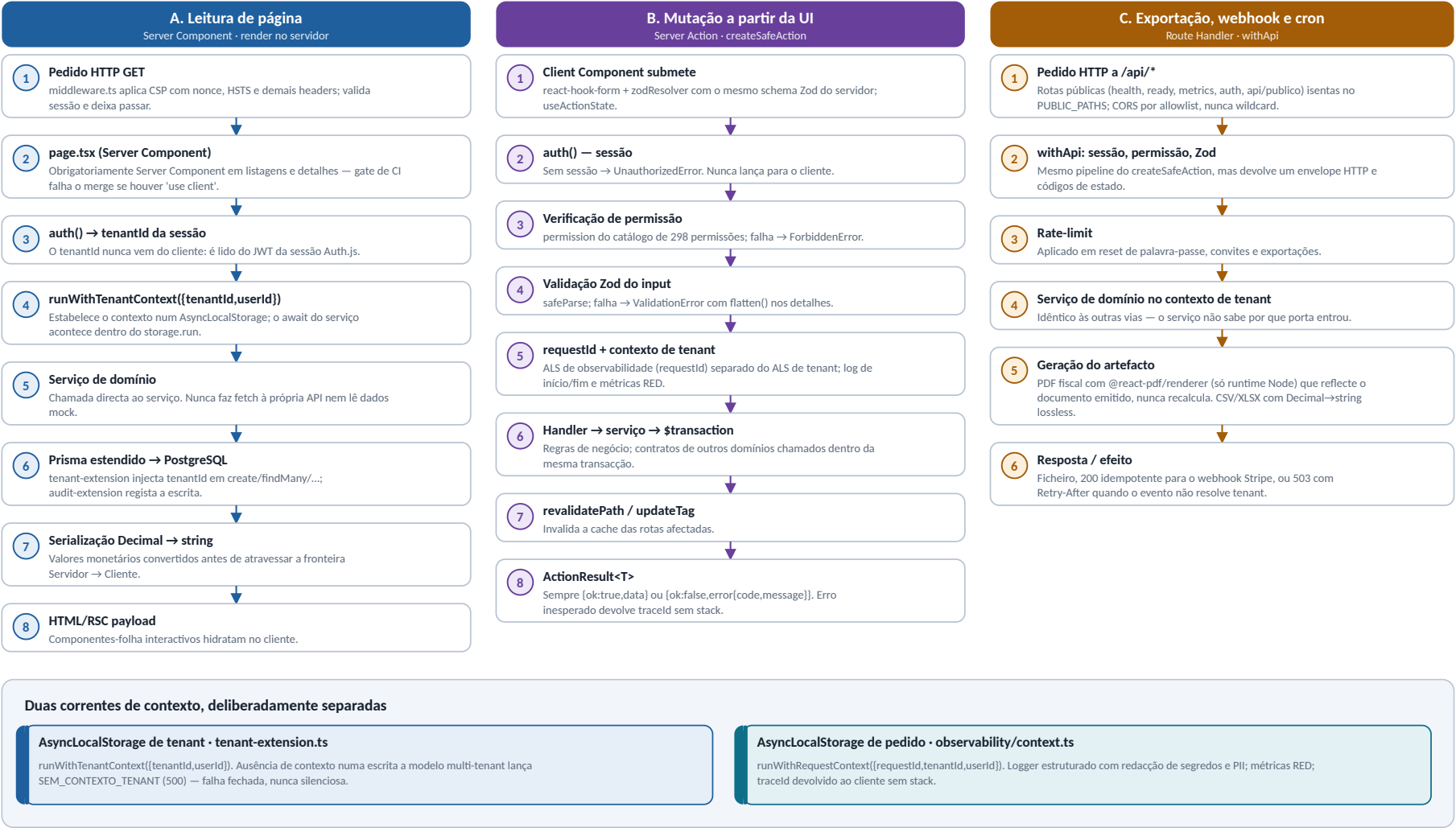


Figura 4 — As três vias de entrada e as duas correntes de contexto. A separação dos dois AsyncLocalStorage é intencional: o contexto de observabilidade acompanha o pedido mesmo quando não há tenant — fronteiras públicas, webhooks, probes — e o contexto de tenant nunca é contaminado por metadados de tracing.

4. Modelo de domínio e contratos

O diagrama seguinte usa o domínio Comercial como caso representativo: é o que consome mais contratos externos e o que concentra as regras de negócio mais delicadas.

4.1 Dimensão do modelo

SCHEMA DE DOMÍNIO	MODELOS	ENUMS
Pessoas & Projectos	50	56
Compras & Serviços	27	22
Finanças	21	18
Operações	21	31
Inventário & Activos	19	14
Comercial & POS	18	21
Autenticação e RBAC	9	0
Plataforma	8	7
Tenant	1	0
Total	174	169

12 migrações aplicadas desde o `init`. Em produção usa-se sempre `migrate deploy`; `migrate dev` exige terminal interactivo e nunca é executado fora do posto de trabalho.

4.2 Hierarquia de erros

Todos os erros de negócio herdam de uma classe base com código estável e estado HTTP. O código é parte do contrato: a interface reage a `STOCK_INSUFICIENTE`, não à mensagem.

ERRO	HTTP	QUANDO
<code>UnauthorizedError</code>	401	sem sessão
<code>ForbiddenError</code>	403	sem a permissão declarada
<code>NotFoundError</code>	404	inexistente ou de outro <i>tenant</i>
<code>ValidationError</code>	422	falha do <i>schema</i> Zod
<code>BusinessRuleError</code>	409	regra de domínio violada

Uma Server Action **nunca lança** para o cliente: devolve sempre um resultado discriminado. Erros inesperados são registados com *stack* no servidor e devolvem apenas um `traceId`.

4.3 Validação partilhada

Existem 25 ficheiros de *schemas* Zod — 24 por módulo mais um de utilitários partilhados. O **mesmo schema** valida no formulário do cliente (via `zodResolver`) e no servidor (via `safeParse` no pipeline da action). Divergir é impossível por construção.

Biblioteca de padrões de interface

14 componentes compõem toda a aplicação: cabeçalho de página, tabela de dados, barra de filtros, distintivo de estado, cartão de indicador, casca de detalhe, página de formulário, assistente por passos, guarda de alterações não gravadas, entre outros. As páginas compõem-se a partir daqui, nunca a partir dos primitivos.

O mapa estado→variante do distintivo é **único e global**; mapas locais são proibidos, para que o mesmo estado tenha sempre a mesma cor em toda a aplicação.

Figura 5 Diagrama de classes Domínio Comercial: serviços, interfaces consumidas de outros domínios e o agregado Venda.

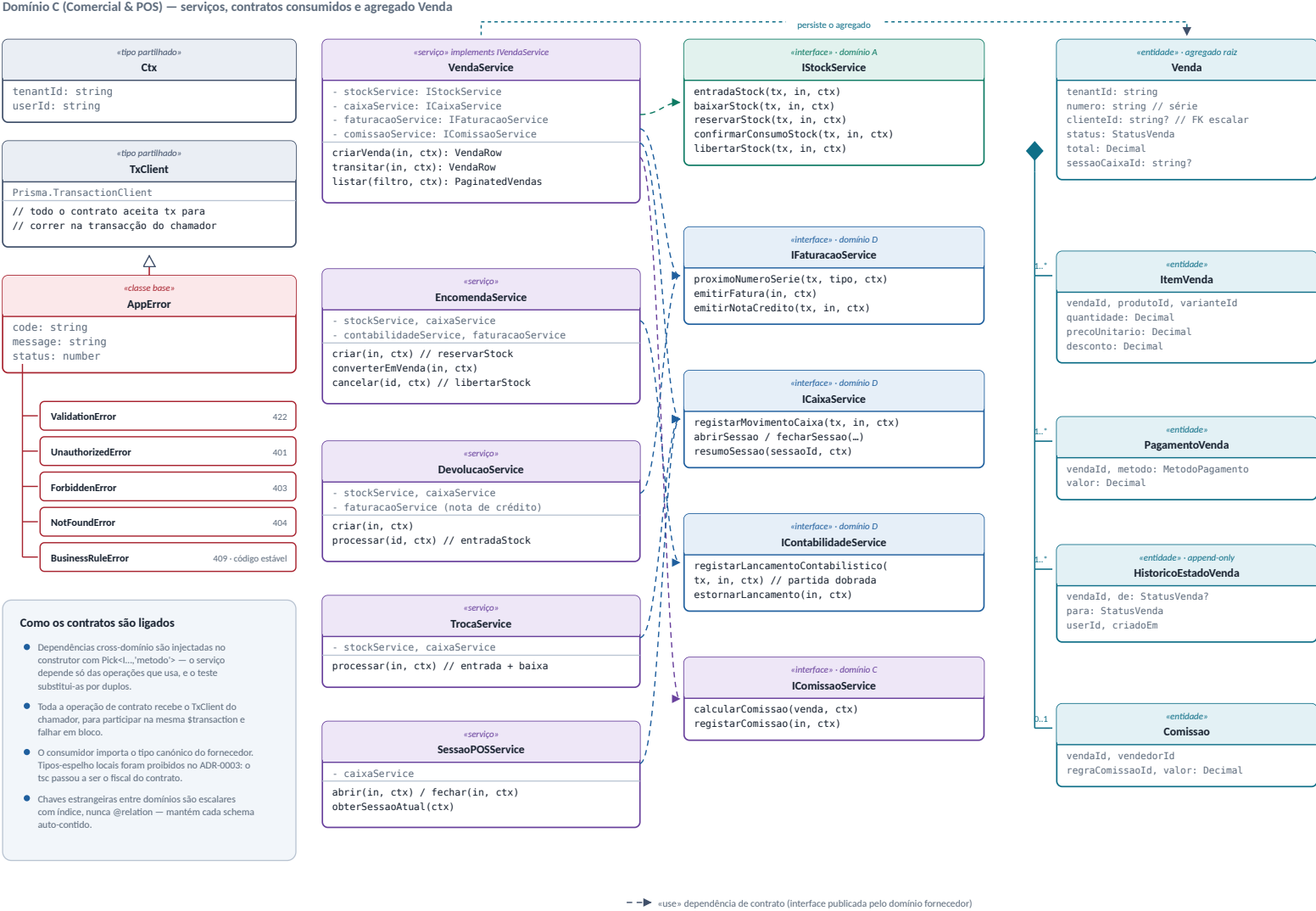


Figura 5 — Serviços, interfaces consumidas e o agregado Venda. As dependências entre domínios são injectadas no construtor com `Pick<I..., 'metodo'>` : cada serviço declara apenas as operações que realmente usa, o que torna os testes triviais de isolar e documenta a dependência no próprio tipo.

5. Sequência de eventos

Venda no ponto de venda

É o fluxo mais crítico do sistema: toca em três domínios, tem de emitir um número fiscal irrepetível, decrementar stock e movimentar caixa — tudo ou nada.

Serve de referência para todos os outros fluxos transaccionais: recepção de compra, facturação, produção e processamento salarial seguem exactamente o mesmo padrão, mudando apenas os contratos invocados.

O que é atómico

Tudo entre **BEGIN** e **COMMIT**, incluindo a numeração fiscal. Se o stock de qualquer item for insuficiente, o número de série também é revertido e não se perde uma posição na série.

O que é deliberadamente não-atómico

O cálculo e registo da comissão do vendedor acontecem **depois** do **commit**. Uma falha aí não deve invalidar uma venda já cobrada ao cliente; fica pendente para reconciliação.

A action nunca lança para o cliente. Devolve sempre um resultado discriminado; um erro inesperado devolve apenas um identificador de rastreio, com o *stack* guardado no servidor.

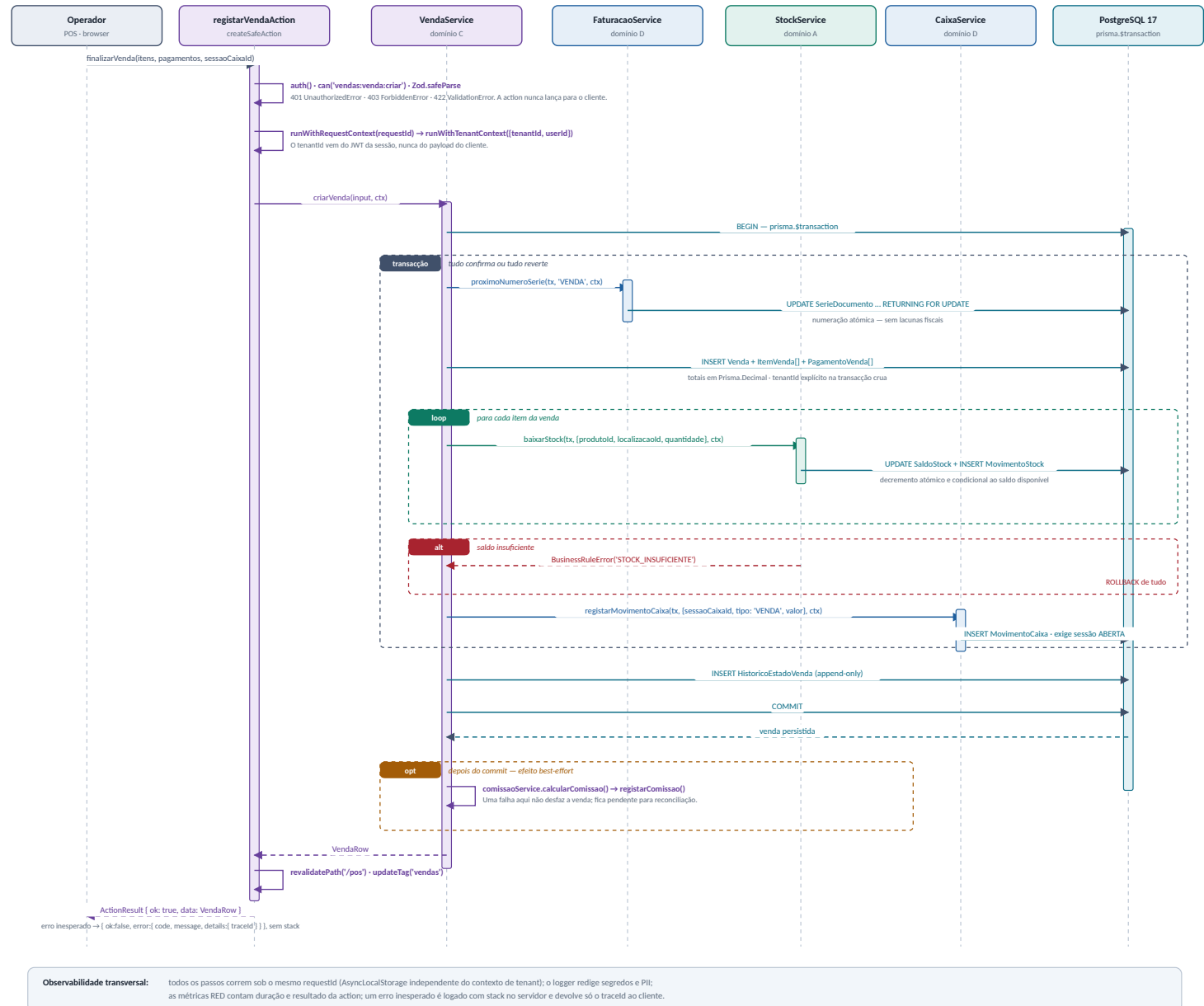


Figura 6 — Venda no POS, do toque do operador à resposta ao cliente.

6. Máquinas de estado

Praticamente toda a entidade com ciclo de vida no GestPro tem a sua máquina de estados declarada — 50 mapas, cobrindo 49 ciclos distintos.

O padrão é sempre o mesmo: um mapa `TRANSICOES_X` que declara, para cada estado, os estados alcançáveis, mais uma função de transição que valida antes de escrever. Um salto inválido lança erro de regra de negócio com código estável. **Nenhum serviço escreve um campo de estado directamente.**

Uma lição aprendida em produção

As constantes que a interface precisa de conhecer vivem num módulo explicitamente seguro para o cliente, separado dos serviços. Importá-las directamente do serviço fazia crashar a listagem no *runtime* React — um erro que a compilação de tipos não apanha e que só o *smoke* autenticado revelou.

Quatro exemplos representativos ao lado, um por domínio; o inventário completo está no rodapé da figura. `TRANSICOES_CONTAGEM_STOCK` é o espelho seguro-para-cliente de `TRANSICOES_CONTAGEM`, daí 50 mapas para 49 ciclos.

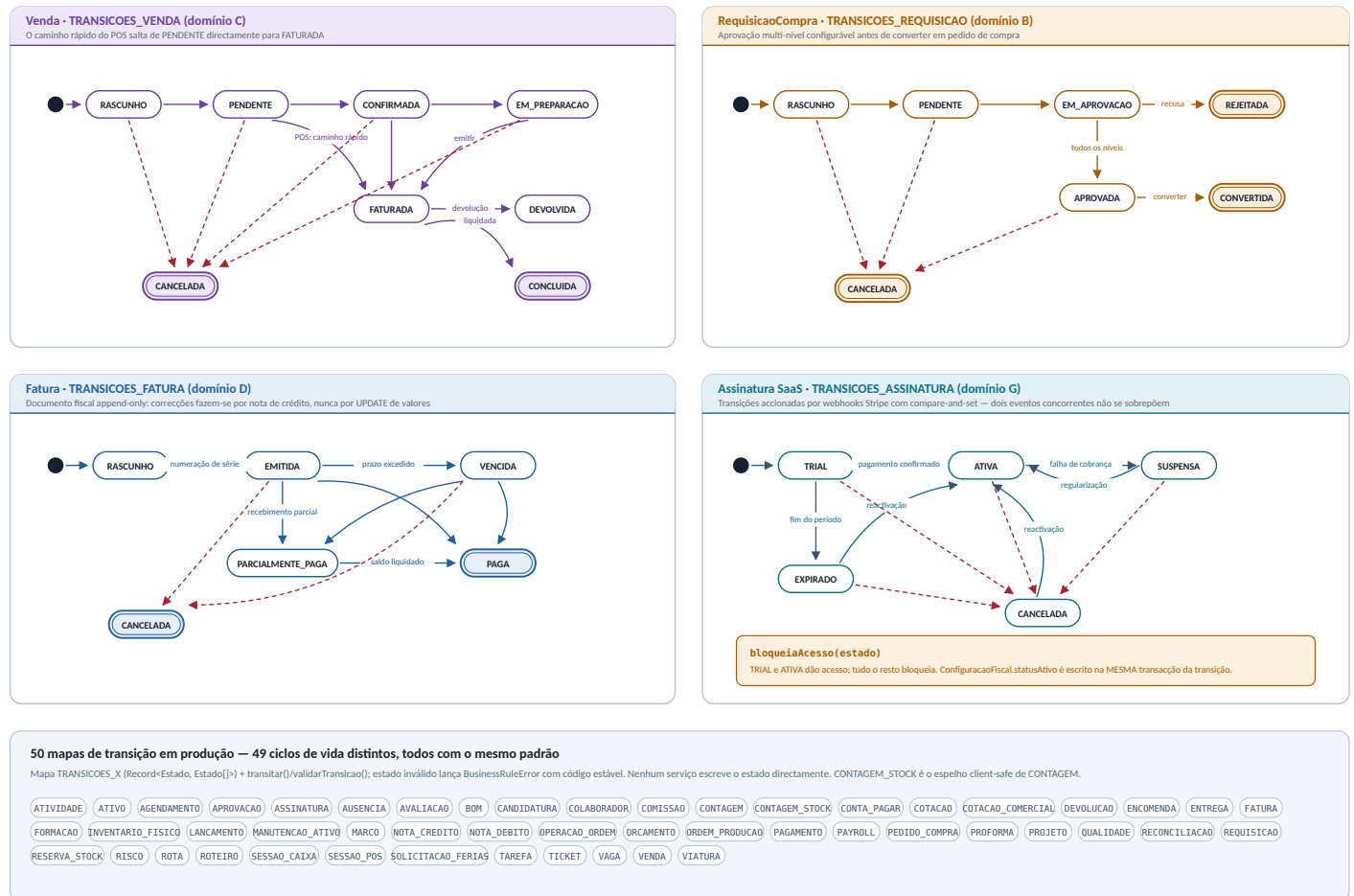


Figura 7 — Quatro ciclos de vida representativos e o inventário completo.

7. Casos de uso

O modelo de autorização é de granularidade fina: 298 permissões nomeadas no formato `modulo:acao[:sub-acao]`.

Estão agrupadas em cinco papéis de sistema que o *seed* cria em cada *tenant* novo — administrador, gestor, financeiro, operador e leitura — e um *tenant* pode definir papéis próprios a partir do mesmo catálogo.

Onde a autorização é imposta

A permissão é declarada na Server Action e verificada pelo pipeline **antes** de qualquer chamada ao domínio. Esconder um botão na interface é apenas cortesia; a recusa acontece no servidor, e um recurso de outro *tenant* devolve 404 em vez de 403 para não confirmar a sua existência.

A figura ao lado agrupa os casos de uso por subsistema. As etiquetas em cada elipse indicam os perfis autorizados a executá-lo.

Casos de uso por subsistema — as etiquetas em cada elipse indicam os perfis RBAC autorizados a executá-lo

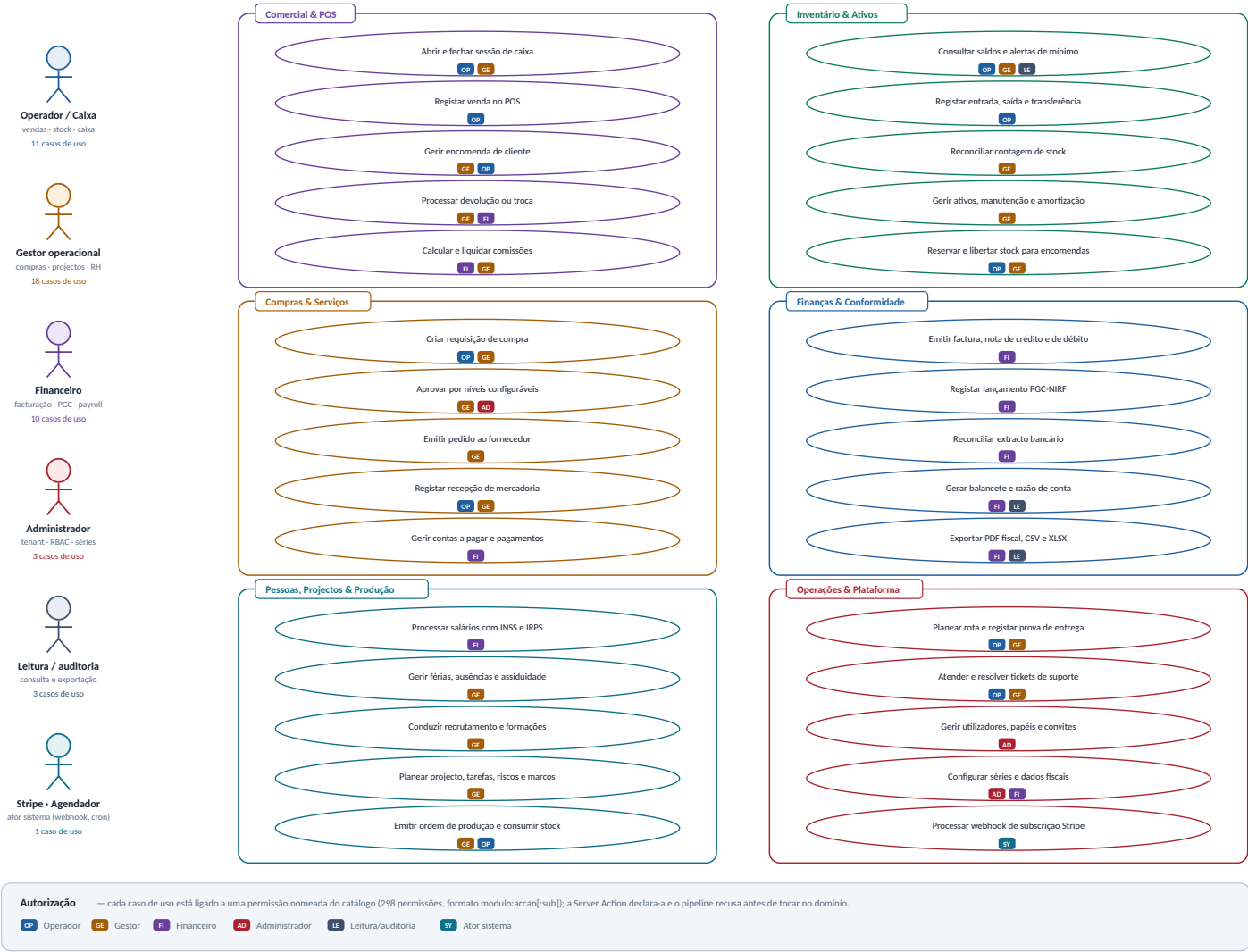


Figura 8 — Casos de uso por subsistema, com os perfis RBAC autorizados.

8. Qualidade, segurança e operação

O programa foi construído com portões de qualidade obrigatórios em cada fase, e com revisão de código formal que rejeitou entregas mais do que uma vez. Isso deixou marca mensurável no produto.

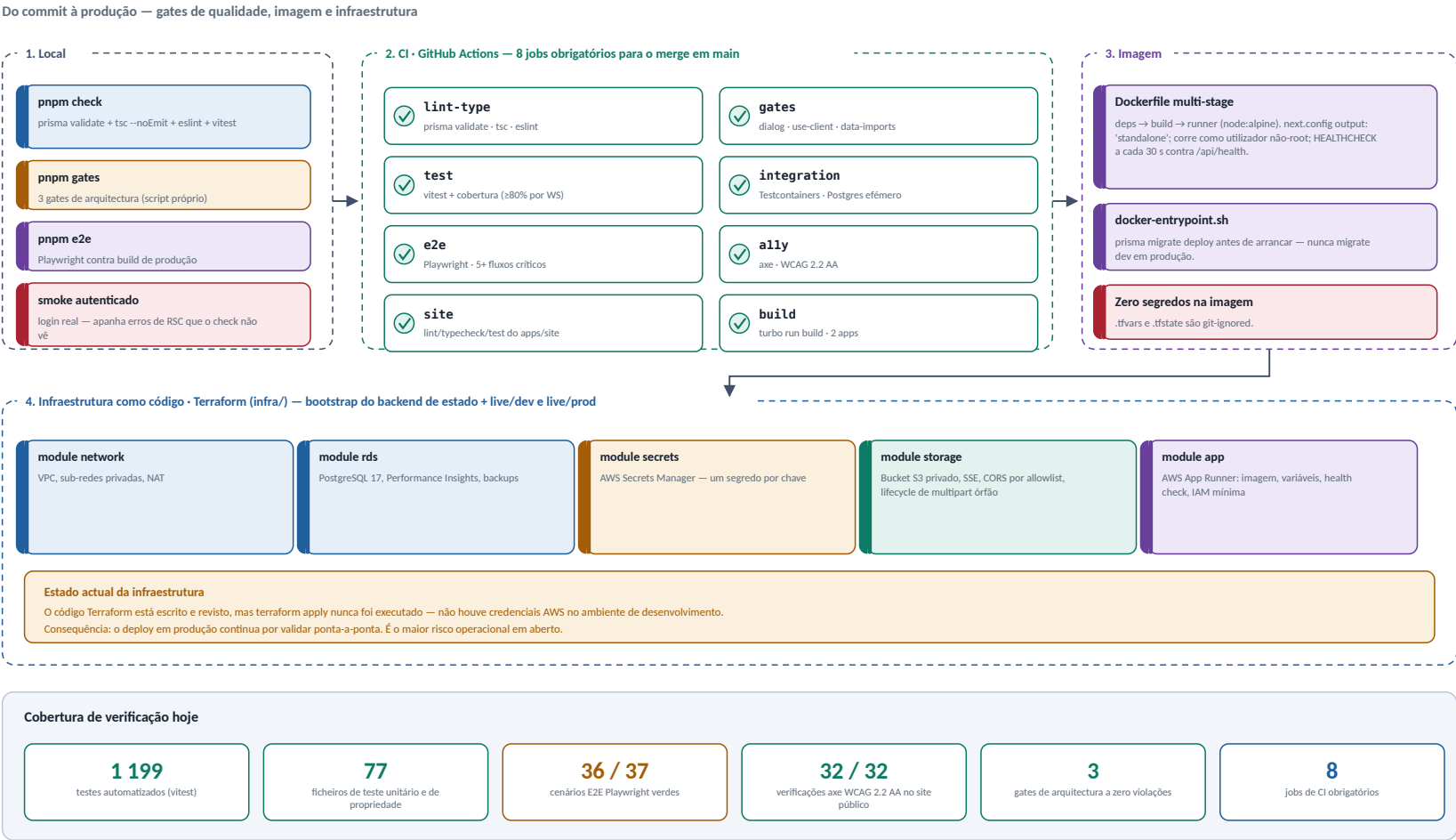


Figura 9 — Do commit à produção. Os oito jobs de CI são todos obrigatórios para o merge em `main`. A última etapa — a infraestrutura — é a única que nunca foi executada.

8.1 Verificação

A verificação está estratificada, porque cada camada apanha o que a anterior não vê.

CAMADA	O QUE APANHA
Tipos	Divergências de contrato entre domínios — desde que não existam tipos-espelho.
Unitários e de propriedade	Regras de negócio, motores de cálculo (o de <i>payroll</i> tem cobertura total), invariantes de paginação.
Integração	Comportamento real contra PostgreSQL efémero em contentor, isolado por execução.
Gates de arquitectura	Modais fora do permitido, <code>'use client'</code> em páginas de listagem, <i>imports</i> de dados mock. Todos a zero.
E2E	Fluxos críticos contra <i>build de produção</i> — o único sítio onde certos erros aparecem.
Acessibilidade	WCAG 2.2 AA em ambos os temas e com movimento reduzido.

Lição registada pela equipa

A verificação de interface exige *smoke* autenticado em *runtime*. A compilação de tipos passa e a aplicação continua a crashar — foi assim que se descobriram quatro falhas de fronteira servidor ↔ cliente que nenhum teste estático apanhava.

8.2 Segurança

CONTROLO	ESTADO
Palavras-passe	argon2 com limitação de tentativas de <i>login</i> persistida em base de dados
Sessão	Auth.js v5, credenciais + JWT, com <i>tenant</i> e permissões na sessão
Cabeçalhos	CSP com <i>nonce</i> por pedido, HSTS, anti- <i>framing</i> , <code>nosniff</code> , política de <i>referrer</i> e de permissões — todos num só dono, o <i>middleware</i>
CORS	Lista branca por origem. Nunca <i>wildcard</i> .
Isolamento	Revisão multi-tenant dedicada por <i>wave</i> ; três fugas cross-tenant apanhadas e fechadas
Armazenamento	URLs assinadas com asserção do prefixo do <i>tenant</i> na escrita, no <i>download</i> e no apagamento
Segredos	Zero no repositório; injectados em <i>runtime</i> pelo Secrets Manager
Limitação de tráfego	EM MEMÓRIA — ver secção 10
CSP em modo estrito	REPORT-ONLY por omissão até haver <i>smoke</i> em produção

Vector recorrente, agora fechado: a chave de armazenamento devolvida ao cliente pelo *presign* voltava nas actions de registo validada apenas como URL. Sem asserção do prefixo, era possível ler ou apagar objectos de outro *tenant* com uma chave forjada. Corrigido na raiz — no registo — e com defesa em profundidade no *download* e no apagamento.

8.3 Observabilidade

Registo estruturado com redacção de segredos e dados pessoais, identificador de pedido propagado por contexto, métricas de taxa/erro/duração, e três *endpoints* operacionais: vivacidade, prontidão (com consulta real à base de dados) e métricas protegidas por segredo.

Os envelopes de Server Action e de Route Handler estão instrumentados sem alterar contratos: erros inesperados devolvem `traceId` ao cliente e guardam o *stack* no servidor.

O que falta na observabilidade

O SDK de OpenTelemetry está configurado, mas não há evidência de um *backend* de tracing ligado nem de painéis construídos. Métricas expostas sem ninguém a observá-las não são observabilidade — são potencial.

8.4 Deploy

Imagem Docker multi-fase com saída autónoma, utilizador não-privilegiado e verificação de saúde periódica. O ponto de entrada aplica as migrações antes de arrancar o servidor.

A infraestrutura está descrita em Terraform com *bootstrap* do próprio backend de estado e ambientes `dev` e `prod` separados: rede com sub-redes privadas, base de dados gerida, gestor de segredos, bucket privado e serviço aplicacional.

9. O que já foi feito

A construção decorreu entre 10 de Julho e 24 de Julho de 2026, em sete *waves*, com agentes a trabalhar em paralelo sobre *worktrees* separadas e ordem de *merge* determinística. Todas as *waves* fecharam com revisão de código formal e portão verde.

WAVE	ÂMBITO	ESTADO	O QUE FICOU ENTREGUE E COMO FOI VERIFICADO	TESTES
0	Fundação de <i>backend</i>	FECHADA	Schema multi-ficheiro, extensões de <i>tenant</i> e auditoria, hierarquia de erros, pipelines <code>createSafeAction</code> e <code>withApi</code> , autenticação com <code>argon2</code> e limitação de tentativas, <i>seed</i> de RBAC e plano de contas.	7
1	Contratos de domínio	FECHADA	144 modelos e as interfaces entre os sete domínios. Rejeitada à primeira com seis bloqueadores: os consumidores tinham criado tipos-espelho dos contratos que já divergiam. A correcção eliminou os espelhos e tornou o compilador o fiscal dos contratos.	56
2	Implementação de domínio	FECHADA	Serviços, testes de propriedade e Server Actions dos sete domínios. Rejeitada com duas fugas cross-tenant. A remoção de um <code>as any</code> num domínio revelou oito bugs escondidos, seis deles escritas sem <code>tenantId</code> .	512
3	Integração transaccional	FECHADA	Os cinco pontos de ligação real entre domínios substituíram os esboços: venda→stock→caixa, recepção→stock→conta a pagar, factura→contabilidade, produção→stock, numeração unificada.	569
UI 0-2	Modernização da interface	FECHADA	Tokens de tema e modo escuro, biblioteca de padrões, <i>golden standard</i> sem modais replicado em 219 páginas, remoção total dos dados mock, POS em ecrã inteiro, assistentes e quadros <i>kanban</i> . Verificação por <i>smoke</i> autenticado além da compilação.	569
4	Funcionalidades em falta	FECHADA	Reconciliação bancária, contagem e reconciliação de stock, processamento salarial com INSS e IRPS, recrutamento, benefícios e correcções de RH. Seis agentes em paralelo.	767
5	Produção e funcionalidades	FECHADA	Encomendas, devoluções e trocas; projectos com riscos e qualidade; relatórios e PDF fiscal; notificações e e-mail; observabilidade; CI/CD; infraestrutura; <i>hardening</i> de segurança. Três entregas rejeitadas , incluindo três bloqueadores transaccionais em vendas.	952
6	Site e onboarding SaaS	FECHADA	Conversão em monorepo, site de marketing com acessibilidade verificada em 32 cenários, registo <i>self-service</i> , subscrições Stripe. Rejeitada por dois bloqueadores de concorrência em <i>webhooks</i> , corrigidos com <i>compare-and-set</i> .	1 148
7	Último quilómetro	FECHADA	Armazenamento S3 com URLs assinadas, rotas em falta, ligação de formulários ainda simulados a actions reais. Três entregas rejeitadas pelo mesmo vector cross-tenant no armazenamento, fechado na raiz.	1 199

O que a revisão formal comprou

Treze rejeições ao longo do programa, em onze entregas distintas, quase todas por **isolamento de tenant** ou **atomicidade transaccional** — precisamente as duas classes de defeito que um cliente descobriria em produção e que custariam confiança, não horas.

O que os números mostram

De 7 para 1 199 testes; de 144 para 174 modelos; de dados 100% simulados para zero. A trajectória é de um protótipo convertido em sistema, não de um sistema construído de raiz.

Fora de âmbito por decisão

O *chatbot* incorporado foi removido a pedido do responsável, com a rota, o *hook*, o componente e a dependência. Optimização de rota, portal do motorista e eventos assíncronos de transporte ficaram explicitamente adiados.

10. O que ainda não foi feito

Nada nesta lista é uma funcionalidade de negócio em falta. É tudo trabalho de **validação, operação e fecho de fronteiras externas** — o que faz sentido, dado que o programa nunca teve credenciais de nuvem nem um ambiente de produção.

LACUNA	BLOQUEIA	SITUAÇÃO EXACTA E CONSEQUÊNCIA	ESFORÇO
1 Infraestrutura nunca provisionada	PRODUÇÃO	O código Terraform existe, foi revisto e teve quatro correcções aplicadas (NAT, <i>Performance Insights</i> , segredos individuais, ficheiros de <i>lock</i>), mas <code>terraform plan</code> e <code>apply</code> nunca correram por ausência de credenciais AWS. Nenhum recurso existe. Tudo o que só falha em nuvem real continua desconhecido.	3–5 dias
2 Stripe nunca contactado a sério	RECEITA	As chamadas de saída estão cobertas apenas com o SDK simulado. Não houve <i>smoke</i> contra a API em modo de teste, e os seis preços em USD ainda têm de ser criados no painel da Stripe. O ciclo de cobrança está por provar ponta-a-ponta.	2–3 dias
3 Fiscalidade MZ da subscrição	RECEITA	O ADR-0009 fixou USD como moeda de facturação do SaaS, mas deixou explicitamente por validar o tratamento fiscal moçambicano dessa facturação. Está assinalado como bloqueante antes de produção e continua em aberto.	Decisão + assessoria
4 Limitação de tráfego distribuída	REGISTO PÚBLICO	A porta hexagonal está desenhada e testada, mas o único adaptador é em memória, por processo. Com mais do que uma instância — ou com reinícios — os limites deixam de valer. Necessário antes de abrir o registo ao público.	1–2 dias
5 Auditoria dos documentos financeiros	CONFORMIDADE	A extensão de auditoria cobre apenas <code>User</code> , <code>Role</code> , <code>Permission</code> e as tabelas de ligação. O próprio código deixou escrito que lançamentos, facturas e movimentos de caixa seriam acrescentados na Wave 2 — nunca foram. Um ERP com contabilidade sem trilha de auditoria nos documentos é difícil de defender numa inspecção.	2–3 dias
6 Fornecedor de <i>captcha</i>	REGISTO PÚBLICO	Nunca foi escolhido. O campo <code>captchaToken</code> viaja vazio; a mitigação actual é campo-armadilha mais limitação de tráfego — que, como se viu acima, é em memória.	1 dia

 bloqueia produção ·  alto — continua na página seguinte

10. O que ainda não foi feito — continuação

Itens de severidade média e baixa. Nenhum destes bloqueia o arranque em produção, mas todos têm custo se ficarem por resolver.

	LACUNA	BLOQUEIA	SITUAÇÃO EXACTA E CONSEQUÊNCIA	ESFORÇO
7	Limite de tamanho no <i>upload</i>	CUSTO / ABUSO	O limite de 10 MB é aplicado na validação do <i>presign</i> , no cliente e por regra de ciclo de vida do bucket — mas não é imposto pela URL assinada, porque a assinatura por <i>query</i> não suporta condição de tamanho. Exigiria migrar para política de POST.	1 dia
8	Documentos de colaborador	FUNCIONAL	O <i>presign</i> aceita o recurso e a permissão existe, mas não há modelo nem action de registo. O ficheiro sobe e fica órfão. É a única lacuna funcional genuína que encontrei.	1 dia
9	Apagamento de objectos órfãos	CUSTO	A porta de armazenamento expõe <i>delete</i> , mas as actions de remoção de documento em alguns consumidores apagam apenas os metadados. O objecto fica no bucket a custar dinheiro indefinidamente.	1–2 dias
10	Desempenho do site público	AQUISIÇÃO	A base está construída — geração estática, fontes locais, imagens em AVIF/WebP, acessibilidade verificada — mas a meta de Lighthouse ≥95 nunca foi medida e o <i>deploy</i> do site nunca aconteceu.	1–2 dias
11	Locale inglês	EXPANSÃO	Existe como esboço que degrada para Português de Portugal. Não é utilizável comercialmente em inglês.	Semanas
12	Custo-hora de produção	FUNCIONAL	Tabela de taxas horárias por centro de trabalho ficou por implementar desde a Wave 2. O custeio de produção usa um valor por definir.	1–2 dias
13	Teste de carga	ESCALA	Não existe qualquer ferramenta ou cenário de carga no repositório. Não há nenhuma medição de quantos <i>tenants</i> , utilizadores concorrentes ou linhas por tabela o sistema aguenta.	3–5 dias

bloqueia produção · alto · médio · baixo

Esforço agregado

~9 d

itens que bloqueiam a entrada em produção (1, 2, 4) mais a decisão fiscal do item 3

~6 d

itens de severidade alta e média que não bloqueiam, mas têm custo directo (5 a 9)

~8 d

itens de validação e medição sem os quais não há noção de escala (10, 12, 13)

4–6

semanas de calendário, com folga para o que o primeiro *deploy* real revelar

A estimativa que não está nesta tabela

Nenhum dos números acima inclui o que só se descobre quando o sistema arranca pela primeira vez numa nuvem real: limites de ligação da base de dados, latências entre serviços, comportamento do *health check* sob arranque a frio, permissões de IAM demasiado estreitas. É por isso que a fase 1 da recomendação existe isolada — o seu valor não é entregar funcionalidade, é converter incógnitas em tarefas estimáveis.

11. O que deve ser melhorado

Distinto da secção anterior: aqui está o que *funciona*, mas cujo estado actual custará caro à medida que o sistema envelhecer ou escalar. Ordenado por relação entre risco e esforço.

11.1 Correção e robustez

ITEM	DIAGNÓSTICO E PROPOSTA	ESFORÇO
A Bug do interceptor de rota paralela	O interceptor <code>@panel/(.)[id]</code> do <i>golden standard</i> captura o segmento literal <code>novos</code> , porque é um valor válido para <code>[id]</code> . Em <i>build</i> de produção, navegar para <code>/compras/requisicoes/novo</code> mostra a listagem em vez do formulário; o acesso directo pelo URL funciona. É a única falha E2E persistente e vem do <i>commit</i> base de 16 de Julho, anterior às <i>waves</i> 4 a 7. Proposta: restringir o interceptor com um <i>matcher</i> que não colida com rotas estáticas irmãs, e fazer o painel devolver <code>null</code> em vez de propagar 404 ao slot. Como o molde foi replicado, convém verificar os outros módulos.	0,5–1 dia
B Janelas de corrida em notas de crédito	A revisão da Wave 5 assinalou janelas de corrida estreitas na emissão de nota de crédito em devoluções e trocas. Foram aceites como dívida, não corrigidas. Proposta: aplicar o mesmo padrão <i>compare-and-set</i> que resolveu o problema equivalente nas subscrições.	1–2 dias
C Seis achados menores do onboarding	Campo <code>erro</code> do <i>webhook</i> declarado mas nunca escrito; tarefa agendada sem passar pelo pipeline <code>withApi</code> ; <i>token</i> de <i>handoff</i> guardado em claro na tabela de idempotência; <i>login</i> ambíguo quando o mesmo e-mail existe em <i>tenants</i> diferentes. Individualmente pequenos; o <i>login</i> ambíguo tornar-se-á um problema de suporte real assim que houver clientes.	2 dias
D Modo estrito de CSP	A política está em modo de relatório por omissão, à espera de um <i>smoke</i> em produção que nunca aconteceu. Enquanto assim for, a protecção contra injeção de <i>script</i> está a observar, não a bloquear. Proposta: activar <code>CSP_ENFORCE</code> logo após o primeiro <i>smoke</i> , e não deixar arrastar.	Horas

11.2 Escala e operação

ITEM	DIAGNÓSTICO E PROPOSTA	ESFORÇO
E Ausência de camada de cache	Não existe Redis nem equivalente. A invalidação de cache é feita por <code>revalidatePath</code> e <i>tags</i> do <i>framework</i> , o que resolve a renderização mas não alivia a base de dados. Um Redis resolveria três problemas de uma vez: limitação de tráfego distribuída, cache de leitura e sessões. Proposta: introduzi-lo primeiro pelo <i>rate limiting</i> , que é o caso mais urgente e o mais simples.	2–3 dias
F Nenhuma evidência de comportamento sob carga	Nenhum teste de carga, nenhuma medição de latência por rota, nenhuma noção de quantos <i>tenants</i> cabem numa instância. Um ERP multi-tenant sem esse número não consegue precificar nem dimensionar. Proposta: um cenário de carga sobre os três fluxos mais pesados — POS, listagens de inventário e balancete — antes do primeiro cliente com volume.	3–5 dias
G Observabilidade sem destino	Métricas e <i>traces</i> são produzidos mas ninguém os recebe. Proposta: ligar o exportador a um <i>backend</i> gerido e construir três painéis mínimos: saúde do serviço, latência por rota e erros por <i>tenant</i> . Sem isto, o primeiro incidente em produção será diagnosticado a ler <i>logs</i> à mão.	2–3 dias
H Recuperação de desastre por documentar	O módulo de base de dados activa cópias de segurança, mas não existe manual de operação, nem objectivo de ponto de recuperação, nem ensaio de restauro. Uma cópia nunca restaurada é uma hipótese, não uma garantia.	1–2 dias
I Índices e planos de consulta	Os índices foram declarados por convenção durante a modelação, mas não há nenhum registo de análise de plano de execução sobre consultas reais com volume. As listagens com muitos filtros e as agregações contabilísticas são os candidatos naturais a rever.	2–3 dias

11.3 Consistência de código

ITEM	DIAGNÓSTICO
J	Formulários do transporte O módulo usa <code>FormData</code> cru em vez do padrão <code>react-hook-form</code> com <code>zodResolver</code> partilhado. Está assumido como dívida do módulo. Durante a integração, esta escolha partiu a compilação de tipos e obrigou a validar com <code>safeParse</code> para estreitar tipos — sintoma claro de que o padrão da casa existe por boas razões.
K	Schemas Zod locais em projectos Os formulários entregues na especificação de projectos definem <code>schemas</code> locais em vez de importarem os de <code>lib/validations</code> . Recria-se o risco de divergência que o ADR-0003 eliminou nos contratos de domínio.
L	Versão de TypeScript não fixada Um <i>handoff</i> da Wave 7 registou uma divergência de versões entre a raiz e a aplicação, com dois erros pré-existentes nas rotas de PDF que o portão de verificação não veria. Essa divergência não é reproduzível no repositório actual — a raiz não declara TypeScript e o ficheiro de <code>lock</code> resolve 5.8.3 para ambas as aplicações. O que subsiste é a causa: o especificador é <code>^5</code> , não uma versão fixa, pelo que qualquer instalação sem <code>lock</code> pode voltar a introduzir a diferença. Fixar a versão fecha o ponto cego de vez.
M	Avisos de lint tolerados Cerca de 140 violações das novas regras do compilador React foram rebaixadas a aviso durante a Wave 0, com o compromisso de as levar a zero nas waves de interface. Continuam por resolver e mascaram problemas reais de pureza e de efeitos.
N	Volume de componentes de cliente 232 ficheiros dentro de <code>src/app</code> declaram a directiva <code>'use client'</code> . As páginas de listagem e detalhe estão correctamente do lado do servidor — o gate garante-o — mas vale a pena auditar quanto disto é interactividade genuína e quanto é hábito, pelo impacto no pacote enviado ao navegador.

11.4 Documentação e governação

ITEM	DIAGNÓSTICO
O	Documentação funcional desactualizada <code>docs/DOCUMENTACAO.md</code> descreve Next.js 15, acesso a dados por PostgreSQL, serviços em <code>src/services</code> e um <i>chatbot</i> que já foi removido. Nada disso corresponde ao sistema actual. Quem entrar na equipa e ler este ficheiro parte com um modelo mental errado. Proposta: substituí-lo por este documento e por um guia de arranque.
P	Numeração de ADR colidida Três registos de decisão da Wave 5 partilham o número 0005 — motor de PDF, infraestrutura e observabilidade. A referência cruzada por número deixou de ser fiável. Proposta: renumerar e acrescentar um índice.
Q	Convenções em três sítios As convenções normativas vivem em <i>skills</i> , os contratos em <i>handoffs</i> , e o estado em <code>docs/status.md</code> . Funcionou bem para agentes; para uma equipa humana, convém um único ponto de entrada que aponte para os três.

11.5 Evolução arquitectural a considerar

Dividir o domínio de Pessoas & Projectos

Com 50 modelos e 56 enumerações, este *schema* concentra recursos humanos, *payroll*, recrutamento, benefícios, projectos e produção. É quase três vezes a média dos outros. Foi também o ficheiro com mais conflitos de *merge* ao longo do programa. Separar produção e projectos em domínios próprios reduziria o acoplamento sem tocar na arquitectura geral.

Manter o monólito

Não há, neste momento, argumento técnico para decompor o sistema em serviços. A atomicidade dos fluxos de negócio é o activo mais valioso da arquitectura actual, e a fronteira modular está a ser efectivamente defendida por gates automáticos. A decisão certa é reforçar os gates, não distribuir o sistema.

12. Riscos e recomendação

O sistema está numa posição invulgar e favorável: o risco que resta é quase todo de **execução**, não de **concepção**. Isso é bom, porque risco de execução resolve-se com dias de trabalho conhecidos, ao contrário do risco de concepção.

12.1 Riscos principais

RISCO	PROB.	IMPACTO	MITIGAÇÃO
O primeiro <i>deploy</i> revela problemas desconhecidos	ALTA	ALTO	Fazer o <i>deploy</i> num ambiente de desenvolvimento em AWS antes de qualquer compromisso com cliente. É a única forma de converter incógnitas em tarefas.
Abuso do registo público	MÉDIA	ALTO	<i>Rate limiting</i> distribuído e <i>captcha</i> antes de abrir o formulário. Não abrir o registo enquanto ambos não estiverem no lugar.
Questionamento fiscal da facturação SaaS	MÉDIA	ALTO	Fechar o ADR-0009 com assessoria fiscal moçambicana antes de emitir a primeira factura de subscrição.
Inspecção contabilística sem trilha de auditoria	BAIXA	ALTO	Estender a auditoria a lançamentos, facturas e movimentos de caixa. São dois a três dias e fecha uma exposição desproporcionada ao esforço.
Degradação com volume real	MÉDIA	MÉDIO	Teste de carga sobre POS, listagens e balancete; revisão de planos de execução nas consultas mais pesadas.
Erosão da fronteira modular	BAIXA	MÉDIO	Os três gates actuais cobrem interface e dados mock, mas não impedem um <i>import</i> directo entre domínios. Vale a pena acrescentar um quarto gate que o proíba explicitamente.
Concentração de conhecimento	MÉDIA	MÉDIO	O sistema foi construído em duas semanas por agentes coordenados. A documentação de processo é boa, mas nenhuma pessoa percorreu todo o código. Prever tempo de familiarização antes de assumir manutenção.

12.2 Sequência recomendada

Quatro fases, nesta ordem. A regra que sugiro é simples: **não abrir nenhuma frente funcional nova** antes de concluir a fase 2.

Fase 1 • Tornar o sistema operável — 1 a 2 semanas

Provisionar a infraestrutura de desenvolvimento em AWS e executar um *deploy* real. Correr o *smoke* autenticado e a suite E2E contra esse ambiente. Ligar o exportador de telemetria e construir os três painéis mínimos. Documentar o manual de operação e ensaiar um restauro de cópia de segurança.

Critério de saída: a aplicação está de pé em AWS, observável, e sabe-se restaurá-la.

Fase 2 • Fechar os bloqueadores comerciais — 1 a 2 semanas

Introduzir Redis e migrar o *rate limiting*. Escolher e integrar o *captcha*. Estender a auditoria aos documentos financeiros. Executar o *smoke* real contra a Stripe em modo de teste e criar os preços. Fechar a decisão fiscal do ADR-0009. Activar a CSP em modo estrito.

Critério de saída: é possível registar, cobrar e auditar um cliente real sem excepções conhecidas.

Fase 3 • Consolidar — 2 a 3 semanas

Corrigir o interceptor de rota paralela e verificar os módulos que replicaram o molde. Fechar as janelas de corrida das notas de crédito e os seis achados do *onboarding*. Alinhar as versões de TypeScript. Ligar o apagamento de objectos e fechar o registo de documentos de colaborador. Correr o teste de carga e rever os planos de consulta. Substituir a documentação funcional obsoleta.

Critério de saída: zero falhas E2E e nenhum ponto cego no portão de verificação.

Fase 4 • Só então, evoluir

Separar produção e projectos em domínios próprios. Levar os avisos de *lint* a zero. Acrescentar o gate de fronteira entre domínios. Retomar o que ficou explicitamente fora de âmbito: optimização de rota, portal do motorista, eventos assíncronos de transporte, e o locale inglês se houver mercado que o justifique.

Leitura final

O GestPro tem a qualidade estrutural de um sistema construído por quem sabia o que estava a fazer: fronteiras explícitas, invariantes defendidas por automação, dinheiro tratado com o rigor devido, e um histórico de revisão que apanhou defeitos reais em vez de os assinar. O que lhe falta é o percurso que nenhum ambiente de desenvolvimento consegue simular — estar de pé, sob carga, com dinheiro de clientes a atravessá-lo. Esse percurso mede-se em semanas, não em meses, e o investimento a fazer agora é em

validação

, não em funcionalidades.

Anexo A • Onde encontrar cada coisa no repositório

Modelo de dados e acesso

apps/erp/prisma/schema/*.prisma	Um ficheiro por domínio
prisma.config.ts	Fonte de dados (Prisma 7)
src/server/db/client.ts	Cliente estendido e cliente cru
src/server/db/tenant-extension.ts	Isolamento multi-tenant
src/server/db/audit-extension.ts	Trilho de auditoria
src/server/db/paginate.ts	Paginação por cursor
prisma/seed/rbac.ts	Catálogo de 298 permissões

Domínio

src/server/services/<dominio>/	51 serviços, 36 interfaces
src/server/actions/*.actions.ts	231 Server Actions
src/lib/state-machines.ts	Transições seguras para o cliente
src/lib/validations/	25 ficheiros de schemas Zod

Fronteiras e transversais

src/server/safe-action.ts	Pipeline de mutação
src/lib/api/with-api.ts	Pipeline de Route Handler
middleware.ts	Cabeçalhos e rotas públicas
src/lib/security/headers.ts	Política de segurança
src/server/security/rate-limiter.ts	Porta de limitação de tráfego
src/server/observability/	Logger, contexto, métricas
src/lib/documents/ , src/lib/reporting/	PDF fiscal, CSV e XLSX
src/components/patterns/	14 padrões de interface

Verificação

scripts/gates.mjs	Gates de arquitectura
e2e/	Cenários Playwright e axe
.github/workflows/ci.yml	8 jobs obrigatórios

Infraestrutura

Dockerfile	Imagem multi-fase
apps/erp/docker-entrypoint.sh	Migrações antes do arranque
infra/bootstrap/	Backend de estado Terraform
infra/modules/	rede, base de dados, segredos, armazenamento, aplicação
infra/live/{dev,prod}/	Ambientes

Governação e histórico

docs/status.md	Fonte de verdade operacional
docs/decisions/	Registos de decisão (ADR)
docs/handoff/	Contratos e dívida por especificação
.kiro/specs/	Requisitos, desenho e tarefas
CLAUDE.md	Convenções e regras invioláveis

Arranque local

docker compose up -d → pnpm db:migrate:dev → pnpm db:seed → pnpm dev .ERP em :3000 , site em :3100 com pnpm dev:site .Verificação completa: pnpm check && pnpm gates && pnpm e2e .